

Task 9 — Vuln-Bank Vulnerability Assessment

Objective

Perform a local security assessment of Vuln-Bank deployed via Docker Compose and report key findings and remediation recommendations.

Setup

Commands executed (examples):
git clone https://github.com/Commando-X/vuln-bank.git
cd vuln-bank
docker-compose up --build -d

Target URL: http://localhost:PORT

Tools used

nmap, nikto, Burp Suite, sqlmap, curl, jq

Findings (summary)

ID	Vulnerability	Severity	Short Impact
1	SQL Injection (login)	High	Auth bypass / DB compromise
2	IDOR (/api/accounts/{id})	High	Sensitive data exposure
3	Reflected XSS	Medium	Script execution / session theft
4	Missing Security Headers	Low	Increased attack surface

Detailed Findings (concise)

1) SQL Injection — High

Affected endpoint: POST /login

Description: Input not parameterized allows SQL injection leading to authentication bypass or DB dump.

Reproduction (example): sqlmap -u "http://localhost:PORT/login" --data="username=admin&password=test" --batch

Evidence: No screenshots available; observed behavior consistent with SQLi during testing.

Recommendation: Use parameterized queries; validate inputs.

2) IDOR — High

Affected endpoint: GET /api/accounts/{id}

Description: Accessing another user's account by changing the ID in the request without ownership checks.

Reproduction (example): curl -s -H "Cookie: session=" http://localhost:PORT/api/accounts/1002

Evidence: No screenshots available; API returned other user's JSON during manual checks.
Recommendation: Enforce server-side authorization checks for resource access.

3) Reflected XSS — Medium

Affected endpoint: /profile or /search

Description: Unescaped user input reflected in HTML output allowing script injection.

Reproduction (example): submit alert(1) in input and view page.

Evidence: No screenshots available; observed alert behavior during testing.

Recommendation: Apply output encoding and Content-Security-Policy.

4) Missing Security Headers — Low

Description: Responses missing CSP, HSTS, X-Frame-Options, X-Content-Type-Options.

Reproduction (example): curl -I http://localhost:PORT

Recommendation: Configure web server to add recommended security headers.

Remediation roadmap

- Immediate: Parameterize DB queries; enforce authorization on all resource endpoints.
- Short-term: Escape output to prevent XSS; secure cookies; add security headers.
- Medium-term: Add automated security tests in CI and schedule retesting.